

## SUMMARY

---

### Q1. Importance of IT Audit

#### Core Idea

IT Audit is a systematic and independent evaluation of IT systems, controls, and policies to ensure **CIA**, compliance, and operational effectiveness.

#### Why Important (Write as points in exam):

- Ensures compliance (ISO 27001, PCI DSS, HIPAA, IT Act)
- Protects information assets
- Identifies risks & vulnerabilities
- Improves IT governance
- Builds stakeholder confidence

#### Example to Stretch Answer:

Enron case — lack of internal controls, segregation of duties, and monitoring led to collapse.

 *In exam:* Add 1–2 lines per bullet → easily reaches 8 marks.

---

### Q2. Types of IT Audits

#### Compliance Audit

- Checks adherence to laws & standards
- Example: HIPAA audit in hospital

#### Operational Audit

- Evaluates efficiency of IT processes
- Example: Incident response effectiveness

#### Integrated Audit

- Combines IT, financial & compliance audits
- Example: SOX audit in public companies

**Conclusion Line (Very Important):**

Integrated audits reduce duplication and give holistic assurance.

---

**Q3. IT Security Audit vs IT Security Assessment****Audit**

- Formal, independent
- Compliance-focused
- Pass/fail result

**Assessment**

- Flexible, improvement-focused
- Gap identification
- Continuous process

**Exam Tip:**

Write **table comparison + one example each** → high scoring.

---

**Q4. Scope, Objectives & Frequency of IT Audit****Scope Includes:**

- Seven IT domains
- Policies, procedures, controls

**Objectives:**

- Verify compliance
- Assess control effectiveness
- Identify risks

**Frequency:**

- Annual (PCI, ISO)
- Periodic internal audits
- Trigger-based audits

---

### Q5. Steps in IT Security Audit

1. Define scope & objectives
2. Identify applicable standards
3. Risk & vulnerability analysis
4. Evidence collection (docs, interviews, testing)
5. Control validation
6. Gap analysis
7. Audit reporting

 *In exam: Write steps with 2–3 lines each.*

---

### Q6. Audit Planning

#### Why Planning is Important

- Defines boundaries
- Saves time & resources
- Reduces audit risk

#### Key Components:

- Scope
  - Objectives
  - Compliance mapping
  - Risk prioritization
  - Methodology
  - Timeline
  - Reporting plan
- 

### Q7. Risk Analysis

**Risk Formula:**

$\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$

**Why Important**

- Guides security investment
- Foundation of ISO 27001
- Prevents disruption
- Improves audit focus

**Example:**

Cloud data → encryption + access control.

---

**Q8. Risk Assessment & Mitigation****Assessment Steps**

- Identify → Analyze → Evaluate

**Mitigation Strategies**

- Avoid
- Reduce
- Transfer
- Accept

**Example:**

Ransomware → backups + patching + training.

---

**Q9. MALR & Security Baselines****MALR**

- Maximum risk organization can accept

**Security Baseline**

- Minimum mandatory controls

**Audit Role**

- Compare actual vs baseline
- 

### **Q10. Threat–Vulnerability–Attack Relationship**

- Threat = potential danger
- Vulnerability = weakness
- Attack = exploitation

#### **Audit Goal:**

Break the chain using preventive & detective controls.

---

### **Q11. Seven Domains of IT Infrastructure**

1. User
2. Workstation
3. LAN
4. LAN-to-WAN
5. WAN
6. Remote Access
7. Application

#### **Importance**

- Structured audits
  - Defense-in-depth
  - Compliance mapping
- 

### **Q12. User Domain**

#### **Includes**

- Employees, contractors, roles

#### **Compliance**

- Least privilege
- Separation of duties
- Training

#### **Business Driver**

- Reduce insider threat
- 

### **Q13. Workstation Domain**

#### **Devices**

- Laptops, desktops, mobiles

#### **CIA Controls**

- Encryption
  - Patch management
  - Backups
- 

### **Q14. LAN Domain**

#### **Devices**

- Switches, routers, servers

#### **CIA**

- VLANs
  - Change management
  - Redundancy
- 

### **Q15. LAN-to-WAN Domain**

#### **Devices**

- Firewalls, IDS/IPS, DMZ

#### **Audit Focus**

- Perimeter security
  - Logging
  - Pen testing
- 

## **Q16. Remote Access & Application Domain**

### **Remote Access**

- VPN, MFA, authentication servers

### **Application Domain**

- Servers, databases, backups

### **Compliance**

- Encryption
  - Logging
  - Patch management
- 

## **Q17–20. BCP & DR**

### **BCP**

- Business survival

### **DR**

- IT recovery

### **DR Sites**

- Hot (fast, costly)
  - Warm
  - Cold
  - Cloud DR
- 

## **Q21. Data Center Failure Case**

## **Impact**

- Downtime
- Financial loss
- Reputation damage

## **Controls**

- DR site
  - Backup
  - Communication
- 

## **Q22–23. ISO 27001 & 27002**

- 27001 = WHAT (ISMS, risk-based)
- 27002 = HOW (control guidance)

## **Certification**

- Scope → Risk → Controls → Audit → Improvement
- 

## **Q24–25. Indian IT Act**

### **Important Sections**

- 43, 65, 66, 66F, 72, 79

### **Adjudication**

- Adjudicating Officer
  - Penalties
  - Appeal to TDSAT
- 

## **Q26. HIPAA, GDPR, PCI DSS**

### **HIPAA**

- PHI protection



## **GDPR**

- EU personal data

## **PCI DSS**

- Cardholder data
- 

## **Q27–28. CAATs**

- Audit software
  - Log analysis
  - Sampling
  - Continuous auditing
- 

## **Q29–30. CIA Triad**

- Confidentiality → Access control
  - Integrity → Change management
  - Availability → BCP & DR
- 

## **Q31. SOC Reports**

- SOC 1 → Financial
  - SOC 2 → Security & Trust
  - SOC 3 → Public assurance
- 

## **Q32. Pen Testing & Config Validation**

- Finds vulnerabilities
  - Verifies secure settings
  - Required by PCI & ISO
-

### **Q33. Governance & Compliance**

- Governance = Direction
- Compliance = Adherence

Frameworks: COBIT + ISO

---

### **Q34. Audit Documentation**

- Policies
  - Procedures
  - Logs
  - Reports
  - Evidence
- 

### **Q35. Risk + BCP + DRP Integration**

- Risk identifies priorities
  - BCP keeps business running
  - DR restores IT
-